

Zero trust using Network Micro Segmentation

Nabeel Sheikh
Electrical and Computer Engineering
Stevens Institute of Technology
Hoboken, NJ, USA
nsheikh@stevens.edu

Mayur Pawar
Cybersecurity Dept
PricewaterhouseCoopers LLP
Toronto, Canada
mayur.p.pawar@pwc.com

Victor Lawrence
Electrical and Computer Engineering
Stevens Institute Of Technology
Hoboken, NJ, USA
vlawrenc@stevens.edu

Abstract—Current enterprise infrastructures are undergoing significant security transformations as traditional infrastructures and data centers are being replaced by cloud computing environments hosting dynamic workloads. Current network security best practices are not well suited for traditional data centers where network micro segmentation is required. In this paper, we present a novel network security architecture that supports zero trust approach, based on a concept that inspects network traffic for port and protocol information to allow authorized communication. This approach is demonstrated in a cloud computing data center environment.

Keywords - cybersecurity, micro-segmentation, cloud, transport, authentication, zero trust.

I. INTRODUCTION

In recent years, network-based cybersecurity attacks have increased in both frequency and severity, far outstripping traditional defense methods. For example, a moderately-sized commercial data center network can experience over 100,000 security events per day [1- 4]. These attacks may be launched by a wide range of bad actors ranging from individual hackers to cyber-gangs motivated to create social disruption to large well-organized groups with political or financial intension. Additionally, these attacks have various goals, including compromising critical network infrastructures such as the Domain Name Server (DNS) Systems or a Software Defined Network (SDN) controller.[1]

In response to the growing number and sophistication of cybersecurity threats, a United States Presidential Executive Order on Cybersecurity was issued in February 2013 [4]. This order outlined a clear and present danger from cyber-attacks and made Cyber Defense a national priority for organizations such as the Department of Homeland Security and the National Science Foundation. In particular, this Executive Order included a call to action which tasked the National Institute of Standards and Technology (NIST) with creating a set of voluntary policies and guidelines to help develop the U.S. cybersecurity framework [4]. In response to this request, numerous federal agencies and industry representatives from the finance, utility, and telecommunication sectors began to develop a fundamentally different approach to cybersecurity, taking into account dynamic environmental trends such as pervasive mobility and big data analytics. The resulting report by NIST proposed the so-called “zero trust model” for information security. While this novel architecture is still in development, many of the elements described in this framework are not commercially available at this time, significant progress has been made in recent years towards the development of tools to support zero trust architectures. The importance of cyberinfrastructure has since been reinforced by additional Executive Orders in this area.

Zero trust is intended to provide a dynamically scalable security infrastructure that can be applied across many different types of organizations. A fundamental principle of zero trust involves authorizing secure communication between the resources, regardless of their environment and location, and assuming all network communication is a threat until it is attested, authorized, and secured. This is not merely an extension of security principles such as deny by default, least privileges, or role-based access control. Rather, it redefines the approach to ring-fence the application resources to whitelist traffic between them, a fundamental principle in which resources to be protected are grouped together and securely isolated or partitioned to limit unauthorized access. [1]

In this paper, we have used Illumio a network micro-segmentation tool to demonstrate Zero Trust at the network layer, this tool uses the concept of labeling to write policies to whitelist traffic between the source and the destination. The tool has two major components Policy Compute Engine (PCE) which is the brain of the tool and Virtual Enforcement Node (VEN) agent that send telemetry traffic information between the source and destination to the PCE. The policy compute engine is used for writing and enforcing the policies based on the traffic information sent to whitelist the traffic between the source and the destination. The tool takes over the host-based firewall on the source and destination where the Virtual Enforcement Node (VEN) agents are installed and allow only the whitelisted traffic.

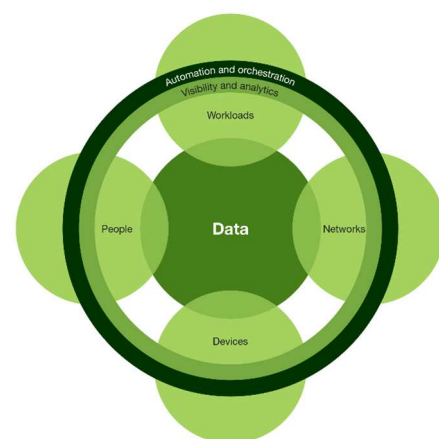


Figure 1: - High Level Zero Trust Eco System by Forrester

II. RELATED WORK

Zero trust architecture involves compensating security controls and threat models that no longer assume that actors, users, systems, or services operating from within the security

perimeter should be trusted by default, and instead everything must be verified before operations. Zero trust involves "least privilege" – only providing access on a need basis. The result of this approach is ring-fencing application resources within the perimeter, also called micro-segmentation, whereby the network is broken into small network zones, each of which requires authorization to access.

Most application resources use Peer-to-Peer (P2P) models, including Windows/Linux operating systems and mesh network architectures. Decentralized Peer-to-Peer communications break the network micro-segmentation model, which voids the zero trust approach. Peer-to-Peer systems also share data with little or no authentication/authorization; therefore breaking the concept of least privilege.

When public and private cloud services work together and unify to deliver a service that is not common, this also breaks the segmentation model.

We deployed three virtual machines named VirtualMachine1, VirtualMachine2, VirtualMachine3 in Microsoft's Azure environment that were connected to the internet and their deployment was successful. In the Illumio tool, these virtual machines are named as R-App, R-DB, R- Web as per their roles in the application stack.

III. FORMAL DEFINITION OF THE COMPONENTS

Numerous logical components make up a Zero Trust ecosystem in an enterprise. As shown in figure 1, these components may be operated on an on-premises environment or through a cloud-based environment. The conceptual framework model in Figure 2 shows the basic relationship between the components and their interactions with each other. From Figure 2, the policy decision point (PDP) is broken down into two logical components: the policy engine and the policy administrator (defined below). The Zero Trust's logical components uses a control plane to write and enforce policies, while application data is transferred via a data plane. [9]

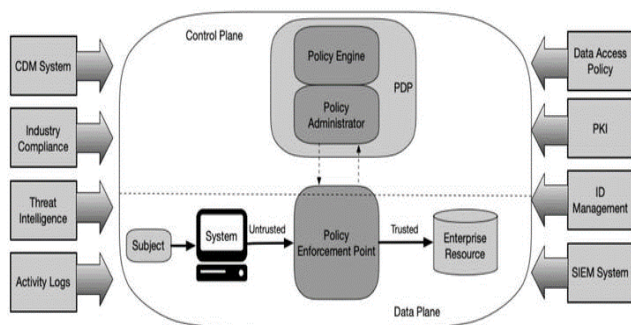


Figure 2: - Core Zero trust Logical Components

Policy engine (PE)[9]: This component is the brain, responsible to provide access to a resource from a given source. The PE uses telemetry network traffic data as well as input from external sources like Continuous Diagnostic Mitigation (CDM) systems, threat intelligence services as input to a trust algorithm that whitelists access between resources. It is integrated with the policy administrator component. The policy engine computes access decisions (as

whitelisted or denied), and the policy administrator enforces them.

Policy administrator (PA) [9]: This component is responsible for establishing and/or shutting down the communication path between a source and a destination (via commands to relevant PEPs). It performs authentication and authorization or validates the credential used by a source to access a resource. It is closely coupled with PE and relies on its decision algorithm to whitelist communication.

Policy enforcement point (PEP) [9]: This component is responsible for opening, monitoring, and eventually closing connections between a source and a destination resource. The PEP communicates with the PA to receive policy decisions/updates from the PE. This is a single logical component in Zero trust architecture but may be broken into two different components: source (e.g., agent on an application workload) and destination (e.g., gateway component in front of resource that controls access). Beyond the PEP is the trust zone hosting the enterprise resource. If the communication is authorized and authenticated, the PA signals the PEP to open the communication. If the session is denied (or a previous approval is countermanded), the PA signals to the PEP to close the communication. Some architecture may treat the PE and PA as a single service; however, it can be divided into two logical components. The PA communicates with the PEP via the control plane when creating the communication path.

In addition to the core components in an enterprise implementing zero trust, several data sources provide input to the policy engine when making access decisions. These include internal local data sources as well as external (i.e., no enterprise-controlled or -created) data sources. These can include:[9]

Continuous Diagnostics and Mitigation (CDM) system: They gather information about the enterprise asset's current state and apply updates to configuration and software components. An enterprise Continuous Diagnostic Mitigation (CDM) system provides the policy engine with the information about the asset making an access request, such as whether it is running the appropriate patched operating system (OS), the integrity of enterprise-approved software components, or the presence of non-approved components and whether the asset has any known vulnerabilities. Continuous diagnostic mitigation systems (CDM) are also responsible for identifying and potentially enforcing a subset of policies on no enterprise devices active on enterprise infrastructure.

Industry compliance system: These systems ensure that the enterprise remains compliant with any regulatory regime that it may fall under (e.g., Federal Information Security Management Act (FISMA), healthcare or financial industry information security requirements).

Threat intelligence feed(s): The information provided these systems can be from multiple sources that take data from internal and/or multiple external sources and provide information about newly discovered attacks or vulnerabilities that are used in the policy decision making. This also includes newly discovered vulnerabilities, newly identified viruses/malwares and reported attacks that the policy engine will use to deny access to from enterprise assets.

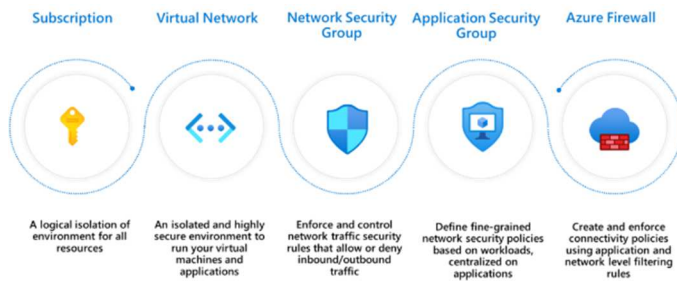


Figure 3: - Maturity model

Network and system activity logs: This system monitors network traffic, aggregates asset logs, resource access activities, and other events that provide real-time (or near real-time) visibility and feedback on the security posture of enterprise architectures

Data access policies: These are the policies and standards about access to enterprise resources. These set of rules could be encoded in (via management interface) or dynamically generated by the policy engine. These policies are the starting point for authorizing access to a resource as they provide the basic access privileges for accounts and applications/services in the enterprise.

Enterprise public key infrastructure (PKI): This system is responsible for generating and logging certificates issued by the enterprise to resources, subjects, services, and applications. This also includes the global certificate authority and the Federal PKI, which may or may not be integrated with the enterprise PKI.

ID management system: This system creates, stores, and manages enterprise user accounts and identity records (e.g., lightweight directory access protocol (LDAP) server). This system contains user identities (e.g., name, email address, certificates) and other enterprise attributes such as role, access attributes, and assigned assets. This system often integrates with other systems (such as a PKI) for artifacts associated with user accounts that may be part of a larger federated community.

Security information and event management (SIEM) system: This system logs, alerts, and stores security-centric information for later analysis. This data is then used to refine enterprise policies and warn of possible attacks against the assets.

IV. DESCRIPTION OF THE SOLUTION/ DESIGNS

In the Maturity model [3], all data is ultimately accessed over the network infrastructure. Networking controls can provide critical controls to enhance visibility and help prevent bad actors from moving laterally across the network once the network is compromised. Networks should be segmented based on the business criticality and requirements (including deep in network micro-segmentation) to provide real-time threat protection, end-to-end encryption, monitoring; analytics should be employed.

Microsoft's Azure provides a wide and diverse range of network segmentation controls available to help create an isolated and protected environment. Here are the three basic

controls that you can use to perform network segmentation in Azure. [3]

Below are the three common segmentation patterns available in Microsoft's Azure environment to deploy workloads:

1. Single Virtual Network
2. Multiple Virtual Networks with peering
3. Multiple Virtual Networks in a hub-and-spoke model

Each of these provides a different type of isolation and connectivity. As to which one works best for your organization is a planning decision is based on your organization's needs.

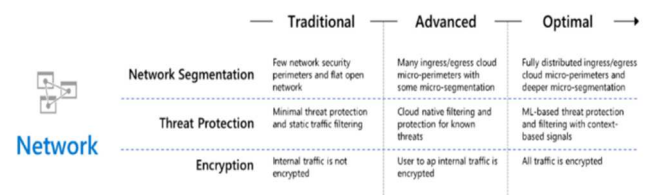


Figure 4: - Segmentation Patterns

The recommended approach [2] in Azure is to use Azure DDoS Protection Service, Azure Firewall, and Azure Web Application Firewall to provide comprehensive threat protection. This setup of having an internet boundary using these services is important in a segmentation architecture since it essentially segments your application stack away from the internet while providing carefully inspected traffic to/from it.

In addition to internet connectivity, your application stack on Azure might need connectivity back to your IT footprint in your on-premises datacenter(s) and/or other public clouds. You have multiple options to achieve that: you can choose to have direct connectivity using Express Route, use our VPN Gateway, or have a more unified distributed connectivity experience using Azure Virtual WAN. The same concept of segmenting away your application stack applies here so that any threats that might affect your datacenter or on-premises network will have a harder time propagating to your cloud platform (and vice-versa) [2].

Illumio's technology [7] decouples security from the underlying network and hypervisor. This security approach can be easily adapted across a variety of enterprise environments, including private data centers, private clouds, and public clouds.

Illumio Adaptive Security Platform (ASP) [7] uses the context (state, relationships, etc.) of workloads (bare-metal and virtual servers, etc.) in the computing environment and keeps security policies intact.

Unlike traditional firewalls that use imperative programming techniques due to static networking constructs, the Illumio Adaptive Security Platform is based on declarative programming and computes security in real-time.[5]

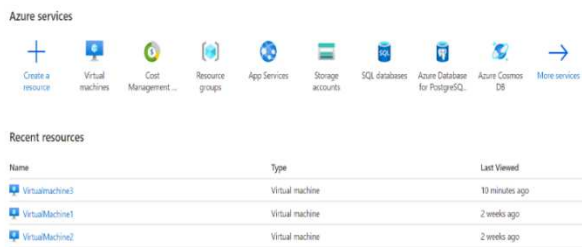


Figure 5: - Three Virtual machines deployment

As shown in Figure 5, the three Virtual machines have been deployed successfully in the Azure environment and they are connected to the internet and have been deployed in an East US location. These servers can SSH (secure shell) and RDP (remote desktop), a connection can be established according to the rules and policy assigned to them. These three servers are the Application server, Database server, and Web server in our production environment in the Illumio tool.

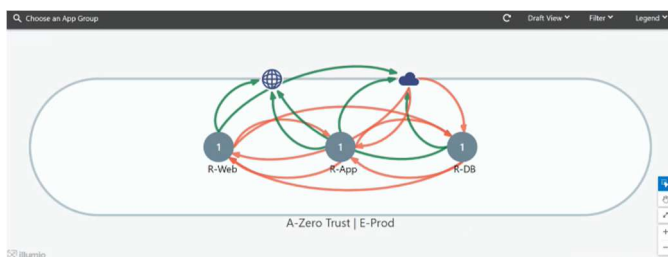


Figure 6: - Zero trust in Illumio Tool

As shown in Figure 6, we have three servers that are connected to the internet and Azure portal, successful deployment of these three servers in Illumio tool. The VirtualMachine1 is named as R-App, VirtualMachine2 as R-DB, and VirtualMachine3 as R-Web in Illumio tool, where the red line indicates that there can be no connection established between them and no packets/queries can be sent between those servers whereas the green line indicates that there is a successful connection between them and have the ability to send and receive data to/from the public internet. Any time you expose a resource to a network you increase threat risk, and with internet exposure, this is further compounded by a large set of a possible threats.[2]

Connectivity	Enforcement	Name	Role	Application	Environment	Location	Last Applied Policy
Online	Visibility Only	App Server	R-App	A-Zero Trust	E-Prod	E-Azure	11/21/2020, 11:44:21
Online	Blocked + Allowed	Web Server	R-Web	A-Zero Trust	E-Prod	E-Azure	11/21/2020, 11:40:09
Online	Blocked + Allowed	DB Server	R-DB	A-Zero Trust	E-Prod	E-Azure	11/21/2020, 11:41:57

Figure 7: - Connectivity in Illumio tool

As shown in Figure 7, the three servers are online in our environment and deployed successfully in the Illumio tool where each server has been given a specific role and the Environment is E-Prod i.e., a production environment and it is synced with three virtual machines in Azure portal.

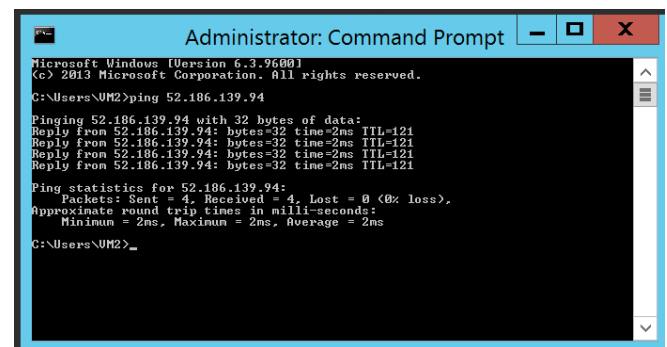
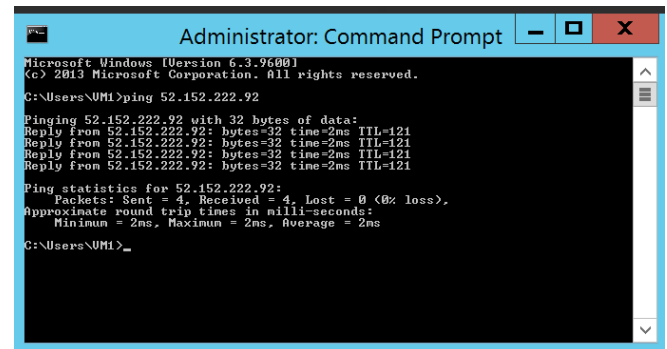


Figure 8: - Remote desktop connection between two servers

As shown in Figure 8, a remote desktop connection is done on the Windows Server R2 2012 version where the VirtualMachine1 having an IP address of 52.186.139.94 and VirtualMachine2 having an IP address of 52.152.222.92 are connected on port 3389 on priority 300 having TCP protocol. The inbound and outbound security groups where both the virtual machine have a priority rule number 100 in Azure portal where they can ping to each other anywhere and connection between them is successful to and can send/receive packets/queries between them.

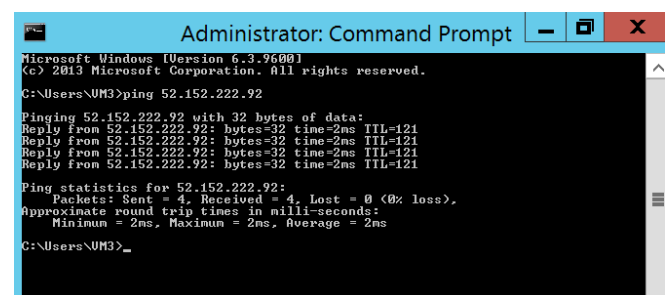


Figure 9: - Virtualmachine3 Remote desktop connection

As shown in Figure 9, Virtualmachine3 remote desktop connection has been done having an IP address of 52.186.143.232 and the connection is established on port 3389 on priority number 300 on Windows Server 2012 having TCP protocol. It has a security group inbound and outbound rules set up where it can connect to anyone and can

send/receive queries/packages from the internet set on priority rule 100.

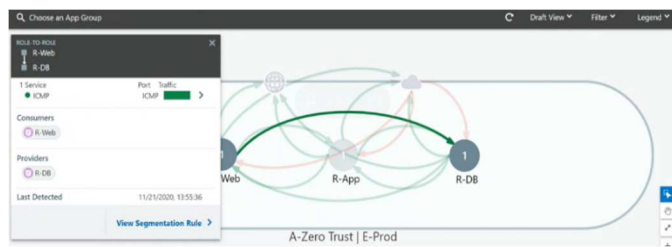


Figure 10: - Private Connection between two servers

As shown in Figure 10, VirtualMachine3 (R-Web) can connect to VirtualMachine2 (R-DB) and there is a successful remote desktop connection between them on private address 10.0.3.4 of R-DB and 10.0.4.4 of R-Web i.e., they cannot receive/send queries/packages to public and internet, and the only private connection is allowed between these two servers having ICMP as a protocol.

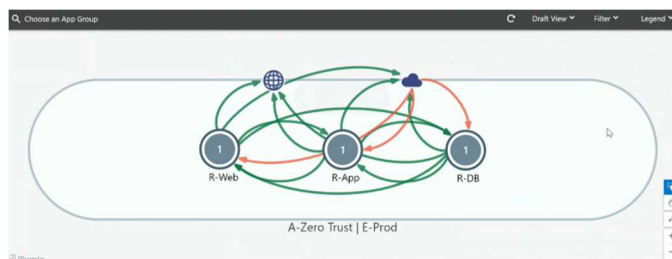


Figure 11: - VirtualMachine2 Disconnected from Internet

ICMP is used to test the reachability of the systems. Although ICMP messages are contained within standard IP packets, ICMP messages are usually processed as a special case, distinguished from normal IP processing. In many cases, it is necessary to inspect the contents of the ICMP message and deliver the appropriate error message to the application responsible for transmitting the IP packet that prompted the ICMP message to be sent. [6]

Many commonly used networks utilities are based on ICMP messages. The traceroute command can be implemented by transmitting IP datagrams with specially set IP TTL(Time to live) header fields, and looking for ICMP time exceeded in transit and Destination unreachable messages generated in response. The related ping utility is implemented using the ICMP echo request and echo reply messages. [8]

As shown in Figure 11, VirtualMachine2 is disconnected from the Internet and only ICMP is allowed between your workloads. R-Web, R-App, R-DB can send/ receive packets or queries on their private connection between them.

Experiment Results

V. EXPERIMENTAL RESULTS

SSL (Secure Shell) allows web browsers and web servers to communicate over a secure connection. The data is encrypted when being exchanged between the source and the destination

on a network. SSL (Secure Shell) helps guarantee that the data will not be altered in transit by that third party.

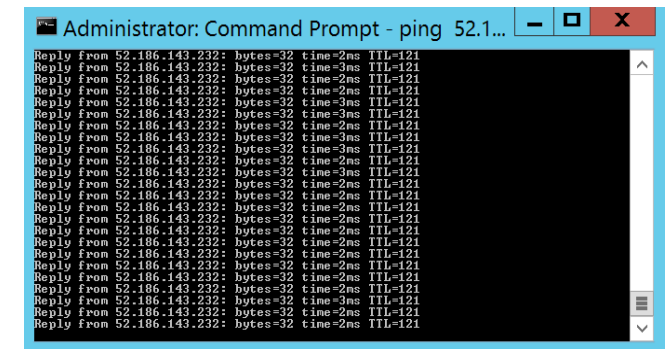


Figure 12: - Remote desktop between two virtual machines

As shown in Figure 12, a remote desktop connection has been established between VirtualMachine1 (R-App) and VirtualMachine3 (R-Web), as we can see these two virtual machines can send/receive queries/packages and VirtualMachine2 (R-DB) cannot connect to these machines and internet as the protocol policy and rule has been set that the packets/queries can only be sent/receive to those servers which are trusted.

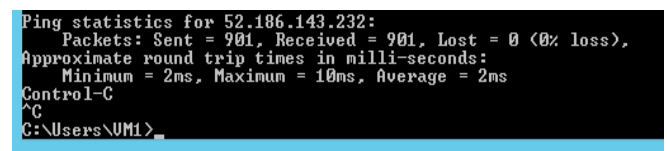


Figure 13: - Packets sent between two servers

As shown in Figure 13, the total number of packets sent to R-Web and there is a loss of 0% of packets during this connection. Thus, these two servers trust each other according to the protocol and policy level set on the Illumio tool and the network segmentation is successful between them without the loss of queries/packages. The results show that the successful simulation of micro-segmentation while sending a data packet with no packet loss. These results indicate there is no collision and congestion in network traffic.

VI. DRAWBACKS

In terms of real-world deployment of network based micro-segmentation, it is difficult to map business-based segmentation to networking requirements. The organization's network infrastructure should be ready to adapt and participate in the configuration.

VII. CONCLUSION

In this paper, we have analyzed and implemented the zero trust concept in our environment. We created a three-tier application (Web, application, and database tier) in the Azure environment for our experimental purpose and collecting data whitelisted traffic between the servers. Whitelisting traffic means allowing servers to communicate with each other only on the port and protocol that it is supposed to; thus, demonstrating the foundation of zero trust at the network level.

During the implementation, we learned that by using the concept of labeling, policies can be written to whitelist the traffic between the source and the destination, thus further micro-segmenting the enterprise network to control the traffic between the source and the destination.

Future work uses a test scenario of high traffic compared to low traffic in the network so that performance comparisons can be obtained. Another approach the performance of a zero trust security model based on micro-segmentation using brands from other vendors such as NSX VMware.

VIII. ACKNOWLEDGEMENT

The authors gratefully acknowledge the support of all the references mentioned below, especially Illumio on which zero trust approach was successfully tested. The authors also gratefully acknowledge the support of Stevens Institute of Technology and PricewaterhouseCoopers LLP Canada.

IX. REFERENCES

- [1] <https://www.blackridge.us/sites/default/files/IEEE-Implementing-Zero-Trust-Cloud-Networks-with-Transport-Access-Control.pdf>
- [2] <https://www.researchgate.net/journal/Advances-in-Science-Technology-and-Engineering-Systems-Journal-2415-6698>
- [3] <https://www.microsoft.com/security/blog/2020/06/15/zero-trust-part-1-networking/>
- [4] U.S. Presidential Executive Order, "Improving critical infrastructure cybersecurity", (February 12, 2013), <http://www.whitehouse.gov/the-press-office/2013/02/12/executive-order-improving-critical-infrastructure-cybersecurity> (last accessed February 25, 2015)
- [5] <https://www.microsoft.com/enus/security/business/zero-trust>
- [6] <https://www.uk.insight.com/en-gb/content-and-resources/articles/cloud-hub/2017-07-31-micro-segmentation-on-microsoft-azure-and-nsg>
- [7] <https://en.wikipedia.org/wiki/Illumio>
- [8] https://en.wikipedia.org/wiki/Internet_Control_Message_Protocol
- [9] NIST Special Publication 800-207 - Scott Rose Oliver Borchert Stu Mitchell Sean Connelly
- [10] C. DeCusatis, P. Liengtiraphan, A. Sager and M. Pinelli, "Implementing Zero Trust Cloud Networks with Transport Access Control and First Packet Authentication," 2016 IEEE International Conference on Smart Cloud (SmartCloud), New York, NY, 2016, pp. 5-10, doi: 10.1109/SmartCloud.2016.22.
- [11] M. Mujib and R. F. Sari, "Performance Evaluation of Data Center Network with Network Micro-segmentation," 2020 12th International Conference on Information Technology and Electrical Engineering (ICITEE), Yogyakarta, 2020, pp. 27-32, doi: 10.1109/ICITEE49829.2020.9271749.
- [12] L. Deri and A. Del Soldato, "An Architecture for Distributing and Enforcing IoT Security at the Network Edge," 2018 IEEE International Conference on Internet of Things (iThings) and IEEE Green Computing and Communications (GreenCom) and IEEE Cyber, Physical and Social Computing (CPSCom) and IEEE Smart Data (SmartData), Halifax, NS, Canada, 2018, pp. 211-218, doi: 10.1109/Cybermatics_2018.2018.00065.
- [13] H. K. Molia and R. Agrawal, "A conceptual exploration of TCP variants," 2014 2nd International Conference on Emerging Technology Trends in Electronics, Communication and Networking, Surat, India, 2014, pp. 1-6, doi: 10.1109/ET2ECN.2014.7044985.
- [14] <https://www.illumio.com>